

COMPTE RENDU

TP 1-3_Chapitre I : Introduction à la Threat Intelligence et recherche de vulnérabilités

Introduction

La Threat Intelligence (ou renseignement sur les menaces) est un ensemble de données, d'analyses et d'informations qui permettent de comprendre les cybermenaces pour mieux les anticiper, les détecter et s'en protéger. En clair, c'est le fait de collecter et analyser des informations sur les attaques informatiques (pirates, virus, vulnérabilités, etc,...).

Il a pour rôle de :

- Anticiper les attaques : voir venir les menaces avant qu'elles ne touchent un système ;
- Détecter plus rapidement les intrusions ;
- Réagir plus efficacement : réponse aux incidents ;
- Renforcer la sécurité globale ;
- Aider les décisions en cybersécurité : prioriser les risques ; choisir les bons outils de protection.

2-Analyse de l'adresse IP

VirusTotal est une plateforme en ligne de cybersécurité qui permet d'analyser des fichiers, des liens, des adresses, des domaines.

Dans notre cas, nous avons effectué l'analyse de l'adresse 8.8.8.8 qui est une adresse publique, adresse de google.

The screenshot displays the VirusTotal web interface for the IP address 8.8.8.8. At the top, a green circle indicates a 'Community Score' of 538 out of 94. Below this, a dark blue header shows '9 detected files communicating with this IP address' and 'AS 15169 (Google LLC)'. The interface includes tabs for 'DETECTION', 'DETAILS', 'RELATIONS', and 'COMMUNITY' (30.2 K). A green banner encourages joining the community. The 'Crowdsourced context' section shows a 'MEDIUM 1' threat level from ThreatFox IOCs. The 'Security vendors' analysis' section lists results from Abusix, ADMINUSLabs, Acronis, and AILabs (MONITORAPP), all marked as 'Clean'.

Security Vendor	Analysis Result
Abusix	Clean
ADMINUSLabs	Clean
Acronis	Clean
AILabs (MONITORAPP)	Clean

Nous avons obtenu un score de 538 qui est un score de réputation/ activité réseau basé sur l'observation de l'adresse sur internet. Ce score n'est pas un score de danger ou de virus.

3-Analyse des services

La commande **nmap -sV 192.168.56.10** : détecte les ports ouverts et les versions des services de la machine cible (192.168.56.10).

```
(nguifotso@nguifotso)~  
$ nmap -sV 192.168.56.10  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-26 15:46 +0200  
Nmap scan report for 192.168.56.10  
Host is up (0.0038s latency).  
Not shown: 999 filtered tcp ports (no-response)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.14 (Ubuntu Linux; protocol 2.0)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 10.10 seconds
```

Comme ports ouverts détectés, nous avons : port 22 (SSH), port 80 (HTTP).

D'après l'analyse de la figure ci-dessus, le service SSH est de version 8.2 qui est une version assez récente (2020), ne possède pas de faille critique.

```
(nguifotso@nguifotso)-[~]
$ searchsploit ssh
```

Exploit Title	Path
(SSH.com Communications) SSH Tectia (SSH < 2.	linux/remote/23082.txt
(SSH.com Communications) SSH Tectia - USERAUT	unix/remote/23156.rb
AbsoluteTelnet 11.12 - 'SSH1/username' Denial	windows/dos/48305.py
AbsoluteTelnet 11.12 - 'SSH2/username' Denial	windows/dos/48010.py
ABUS Security Camera TVIP 20000-21150 - LFI	hardware/remote/51294.txt
Axessh 4.2 - 'Log file name' Denial of Servic	windows/dos/46858.py
Axessh 4.2 - 'Log file name' Local Stack-base	windows/local/46922.py
Axessh 4.2 - Denial of Service	windows/dos/40699.txt
Ceragon FibeAir IP-10 - SSH Private Key Expos	linux/remote/41679.rb
Cisco Catalyst 4000/5000/6000 6.1 - SSH Proto	hardware/dos/20509.pl
Core FTP LE 2.2 - 'SSH/SFTP' Remote Buffer Ov	windows/dos/40828.py
Cypress Solutions CTM-200/CTM-ONE - Hard-code	hardware/remote/50407.py
Debian OpenSSH - (Authenticated) Remote SELin	linux/remote/6094.txt
Dropbear / OpenSSH Server - 'MAX_UNAUTH_CLIEN	multiple/dos/1572.pl
Dropbear SSH 0.34 - Remote Code Execution	linux/remote/387.c
DropbearSSHD 2015.71 - Command Injection	linux/remote/40119.md
Eaton Xpert Meter 13.4.0.10 - SSH Private Key	hardware/remote/45283.rb
EOCA Building Automation System - Hard-coded	hardware/remote/50282.txt
ExaGrid - Known SSH Key and Default Password	linux/remote/41680.rb
F5 BIG-IP - SSH Private Key Exposure (Metaspl	hardware/remote/19099.rb
FaceSentry Access Control System 6.4.8 - Remo	hardware/remote/47067.py
fipsShop - Multiple SQL Injections	asp/webapps/29189.txt
FLIR Thermal Camera F/FC/PT/D - SSH Backdoor	hardware/remote/42787.txt
Fortinet FortiGate 4.x < 5.0.7 - SSH Backdoor	linux/remote/43386.py
FreeBSD OpenSSH 3.5p1 - Remote Command Execut	freebsd/remote/17462.txt
freeSShd - Denial of Service (PoC)	windows/dos/18268.txt
freeSShd 1.0.9 - Denial of Service (DoS)	windows/remote/52342.txt
freeSShd 1.0.9 - Key Exchange Algorithm Buffe	windows/remote/1787.py
freeSShd 1.0.9 - Key Exchange Algorithm Strin	windows/remote/16461.rb
freeSShd 1.2 - 'SSH2_MSG_NEWKEYS' Remote Deni	linux/dos/31218.txt
freeSShd 1.2.1 - 'rename' Remote Buffer Overf	windows/remote/8295.pl
freeSShd 1.2.1 - (Authenticated) Remote Overf	windows/remote/5751.pl
freeSShd 1.2.1 - (Authenticated) Remote Stack	windows/dos/5709.pl
freeSShd 1.2.1 - (Authenticated) SFTP 'realpa	windows/dos/6812.pl

La commande **searchsploit** présente la liste des vulnérabilités connues (CVE/ exploits) liées à Apache.

La sortie de searchsploit révèle plusieurs catégories de vulnérabilités affectant Apache. Les exploits de type Remote Code Execution (RCE) sont les plus critiques car ils permettent à un attaquant d'exécuter du code arbitraire sur le serveur distant sans authentification préalable.

4-Etude d'une CVE

Une CVE est un identifiant unique attribué à une vulnérabilité informatique connue.

CVE-2021-41773 Detail

Description

A flaw was found in a change made to path normalization in Apache HTTP Server 2.4.49. An attacker could use a path traversal attack to map URLs to files outside the directories configured by Alias-like directives. If files outside of these directories are not protected by the usual default configuration "require all denied", these requests can succeed. If CGI scripts are also enabled for these aliased pathes, this could allow for remote code execution. This issue is known to be exploited in the wild. This issue only affects Apache 2.4.49 and not earlier versions. The fix in Apache HTTP Server 2.4.50 was found to be incomplete, see CVE-2021-42013.

Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: 9.8 CRITICAL

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

ADP: CISA-ADP

Base Score: 7.5 HIGH

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

QUICK INFO

CVE Dictionary Entry:

[CVE-2021-41773](#)

NVD Published Date:

10/05/2021

NVD Last Modified:

02/17/2026

Source:

Apache Software Foundation

References to Advisories, Solutions, and Tools

By selecting these links, you will be leaving NIST webspace. We have provided these links to other web sites because they may have

La CVE-2021-41773 est une faille dans Apache http server. Elle permet de standardiser la communication entre chercheurs, éditeurs et outils de cybersécurité.

CVE-2021-41773 est une vulnérabilité de type **Path Traversal** (traversée de répertoire) affectant exclusivement **Apache HTTP Server version 2.4.58**. Elle est causée par une validation insuffisante des entrées lors de la normalisation des chemins URL, permettant à un attaquant de faire pointer une URL vers des fichiers situés en dehors de la racine documentaire (*document root*) du serveur. CVE-2021-41773 est une vulnérabilité de type **Path Traversal** (traversée de répertoire) affectant exclusivement **Apache HTTP Server version 2.4.58**. Elle est causée par une validation insuffisante des entrées lors de la normalisation des chemins URL, permettant à un attaquant de faire pointer une URL vers des fichiers situés en dehors de la racine documentaire (*document root*) du serveur.

Impact

L'impact est double selon la configuration du serveur :

Divulgateion d'information La vulnérabilité permet d'accéder à des fichiers sensibles en dehors du document root.

Exécution de code à distance Bien que le CVE-2021-41773 était qualifié de simple bug de divulgation d'informations, des chercheurs indépendants ont confirmé que la vulnérabilité peut être utilisée pour de l'exécution de code à distance.

Sur le plan des **triade CIA** :

- **Confidentialité** : compromise (accès à des fichiers privés)
- **Intégrité** : compromise si RCE possible (modification de fichiers)
- **Disponibilité** : compromise (risque de prise de contrôle totale du serveur)

Niveau de gravité

Le score CVSS de base est de 7.5 (HIGH), mais en présence du module `mod_cgi` activé, l'exploitation en RCE fait monter la criticité à 9.8 (CRITICAL). Cette vulnérabilité a été exploitée comme zero-day avant même la publication du patch officiel.

Exploitation possible

L'exploitation peut être réalisée manuellement via une requête `curl` ou avec Metasploit en utilisant les deux vecteurs mentionnés plus dans la capture d'écran.

6. Analyse globale de sécurité

6.1 Risques identifiés

L'analyse combinée du scan Nmap, de VirusTotal et de searchsploit permet d'identifier plusieurs risques :

- Risque de déni de service (DoS) : plusieurs exploits référencés permettent de saturer le service Apache et de le rendre indisponible, impactant la continuité d'activité.
- Risque de divulgation d'informations : des vulnérabilités d'Information Disclosure exposent la structure interne du serveur (répertoires, version, configuration), facilitant les attaques ultérieures.
- Risque lié aux services port.

6.2 Service le plus dangereux

Le service le plus dangereux identifié est Apache HTTP qui écoute sur le port 80 qui est un port ouvert.

6.3 Actions recommandées

- Mettre à jour immédiatement Apache et PHP vers les dernières versions stables afin d'éliminer les CVE connues.
- Désactiver les services non nécessaires pour réduire la surface d'attaque.
- Effectuer des audits de sécurité réguliers (pentest, scan de vulnérabilités) pour détecter les nouvelles failles avant qu'elles ne soient exploitées.

7-Lien avec l'entreprise

Un analyste SOC utilise la Threat Intelligence pour corréler les logs internes avec des bases de données externes. Si une IP connue pour être malveillante tente de se connecter, le SOC peut automatiser son blocage.

Il peut anticiper une attaque en surveillant les nouvelles CVE avant qu'elles ne soient exploitées massivement.

Conclusion

Ce TP nous a permis de comprendre la reconnaissance Nmap, l'analyse de vulnérabilité (searchsploit/ CVE). En effet, une menace peut être réelle avant même d'être listée sur VirusTotal. La maîtrise de la chaîne d'outils Nmap vers searchsploit vers recherche de CVE constitue le socle technique d'un analyste en sécurité offensive. Chaque outil joue un rôle précis : Nmap pour la découverte, searchsploit pour la recherche d'exploits, et les bases CVE pour la qualification et la priorisation des risques.

